

Agent 2：企業 AI Agent 工具偏移與風險操作防護

Reporter：陳宥霖、陳敏瑄、康慈軒、呂亭儀

目錄

CONTENTS

01

問題定義

1.1 痛點分析

02

介紹與功能

2.1 專案介紹

2.2 功能介紹

03

參賽組別

3.1 NIICC

3.2 Innoserve

問題定義

痛點分析

➤ 間接 Prompt Injection、長期投毒

- 企業導入 AI 後，外部攻擊者可能透過看似正常的業務文件（如客戶夾帶的報表、外部寄入的信件）**隱藏惡意指令**來欺騙 AI。
- 長期的記憶投毒會讓 **AI 的基礎認知產生偏差**，導致未來的客服回應、自動化流程或數據分析持續基於錯誤的前提運作

➤ Agent 產生幻覺、決策過程視覺化

- 當 AI **產生幻覺**（提供看似專業但完全錯誤的資訊）或做出錯誤操作時，企業若缺乏透明、視覺化的決策溯源機制，將**無法進行事後稽核**、釐清責任歸屬與快速除錯。

➤ Agent 對工具呼叫的權限管控

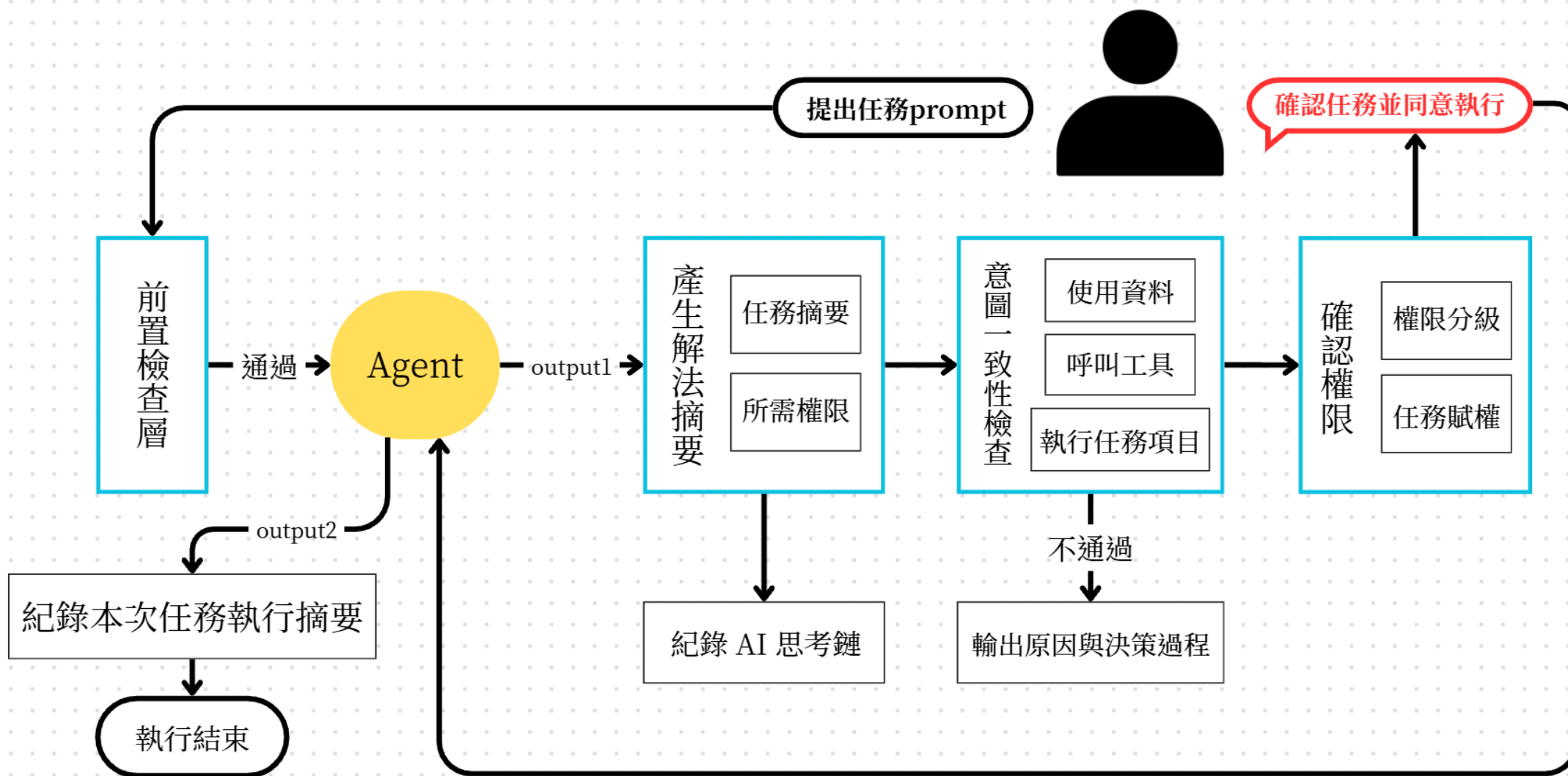
- IT 基礎架構部門難以對 AI 代理實施嚴格的**最小權限原則**。

介紹與功能

專案介紹

- 希望建立一套面向企業 AI Agent 的安全防護機制，讓 Agent 在執行任務時，不只追求完成目標，也能持續受到**任務範圍、權限邊界與操作風險**的約束。
- 系統會從 Agent 是否仍符合原始任務、是否需要使用該項工具、是否可能造成敏感資料外流等角度進行判斷，協助企業在導入 AI Agent 的同時，建立**可控、可信且可追蹤**的使用環境。
- 方案一：OpenClaw 環境
 - 實作時需要處理跨服務工具呼叫、資料流向、外部 API 權限與長期任務紀錄，範圍較大但**更接實際情境**
- 方案二：Codex 環境
 - 實作時需要處理本地或專案環境中的檔案讀寫、指令執行、文件解析、git 變更與工具呼叫控管，**範圍較集中**

專案介紹



前置檢查層

- 處理間接 Prompt Injection、長期記憶投毒問題
- 掃描檔案中是否有惡意句子，過濾後再餵給 Agent
- 現今的做法主要是讓文字先經過檢查後再給 Agent
 - ✓ 無法處理文圖檔案內夾帶的隱藏惡意
- 我們可以嘗試處理更刁鑽的 Prompt Injection，如：
 - ✓ 將惡意指令混在圖片裡
 - ✓ 用零寬度字元隱藏的惡意提示詞

意圖一致性檢查

- 處理 Agent 產生幻覺的問題
- 在執行任務前，將 Agent 執行計劃與原始輸入的語義進行比對
- 現在主流是點對點的檢查，單看某個動作是否合法
- InjecAgent 資料集：包含各種 Prompt Injection，如和金融、資料有關的
- 將安全指令和有惡意提示詞的指令丟進 Agent，產生安全任務和偏移任務
- 計算「安全指令與安全任務的語義相似度」和「安全指令與偏移任務的語義相似度」，以此界定任務是否偏移、統計閾值設定多少較恰當

確認權限

- 處理 Agent 對工具呼叫的權限管控的問題
- 現有方法通常是一開始直接決定所有權限
 - ✓ 出錯時破壞範圍難以控制
- 在呼叫工具前先進行使用者身分驗證確認其權限
 - ✓ 避免混淆代理人
- 執行前告知只需哪些權限，提供使用者修改或授權，並提供高風險建議
 - ✓ 避免過度授權

Agent 行為記錄追蹤

➤ 留下完整可追蹤紀錄

- ✓ 誰發起任務？
- ✓ 原始任務是什麼？
- ✓ Agent 讀了哪些資料？
- ✓ Agent 想呼叫什麼工具？
- ✓ 風險原因是什麼？
- ✓ 系統最後放行、阻擋，還是要求人工確認？
- ✓ 是誰批准的？

參賽組別

NIICC 組別

- 1. 數位運算科技與創新應用組
 - ✓ 資訊安全、人工智慧、生成式 AI、AI 代理
- 備取1：智慧機器科技組
- 備取2：最糟的打算＝體感

Innoserve 組別

➤ 大會專題組——資訊應用組

- ✓ ICT 創新應用、智慧製造、區塊鏈、IoT、AI、大數據、ODF、雲端應用、行動應用、行動支付、智慧聯網、資訊安全、AR/VR、5G、電子商務，如：
 - 區塊鏈技術、具商業價值的大量動態影像即時分析、其他資訊安全應用
- ✓ 歷屆得獎作品題目：
 - 醫學影像之人工智慧化判讀、跨平台緊急救護 APP、AI 書法教學平台
 - 智慧型入侵防禦系統與互動式威脅顧問、防詐

➤ 指定專題組——資安技術組

- ✓ 開發資安相關之新工具/新技術及概念驗證 (POC) /新框架，如：
 - 結合 AI 的各種資安技術、假訊息辨識/追蹤、合成影像辨識技術、惡意程式追蹤/防制
- ✓ 歷屆得獎作品題目：
 - 高安全指紋增強與防偽辨識系統、智慧型入侵防禦系統與互動式威脅顧問
 - 工業控制系統中惡意流量辨識與流量移轉

THANKS